

Vulnerability Scanning & Assessment

Task-3

Objective:

The purpose of this task is to help you understand how cybersecurity analysts and penetration testers **identify weaknesses in a system before attackers do**. This task teaches you:

Objective	Real-world outcome
Perform network reconnaissance	Understand how attackers discover targets
Identify open ports & services	Detect exposed attack surfaces
Detect misconfigurations	Learn what makes systems vulnerable
Use scanners responsibly	Learn professional assessment workflow
Prepare a VA Report	Document findings like a Cybersecurity Analyst

By completing this task, you will take the **first practical step toward becoming a Vulnerability Analyst / Penetration Tester**, which is a core job role in cybersecurity.

Task Description:

You will perform a **professional-grade vulnerability assessment** on the intentionally vulnerable web applications/systems you installed in Task-2 (OWASP Juice Shop / DVWA / Metasploitable2). This assessment simulates how analysts scan real enterprise systems before exploitation, and before patching.

Your responsibility in this task is to:

1. Discover network assets and confirm they are reachable.
2. Enumerate open ports, running services, and their versions.
3. Identify outdated or misconfigured services.
4. Scan for known web application weaknesses.
5. Organize these findings into a formal **Vulnerability Assessment Report (VAR)**.
6. Suggest **realistic remediation** for each issue found.

You are **not yet exploiting vulnerabilities** — only **identifying and documenting them**. Exploitation and deeper web security testing will be part of Task-4.

Scope of This Assessment:

In-scope	Out-of-scope
Your lab systems only	Anything outside your lab
Passive & active scanning	Exploit attempts
Web & network layer visible issues	System destruction / DoS
OpenVAS/Nessus optional scan	Real-world websites

Required Tools & Purpose:

Tool	Purpose
Nmap	Host, ports, & service enumeration
Nikto	Web server misconfigurations
Dirsearch	Find hidden files/directories
OpenVAS / Nessus (optional)	Deep vulnerability mapping
Burp Suite (optional here)	Manual verification

Step-by-Step Activities:

✔ Step 1: Host Discovery

```
swift  
  
nmap -sn 192.168.56.0/24 -oN ~/lab/scans/host-discovery.txt
```

Purpose: Confirm target is alive and visible.

✔ Step 2: Port & Service Enumeration

```
pgsql  
  
nmap -sV -p- <target-ip> -oN ~/lab/scans/full-service-scan.txt
```

Purpose: Identify running services attackers could exploit.

✔ Step 3: Detect Web Vulnerabilities (Initial)

```
perl  
  
nikto -h http://<target-ip>:PORT -o ~/lab/scans/nikto.txt
```

Purpose: Detect outdated components and server misconfiguration.

✔ Step 4: Find Hidden Endpoints

```
perl  
  
dirsearch -u http://<target-ip>:PORT -o ~/lab/scans/dirsearch.txt
```

Purpose: Identify unprotected files/panels commonly abused.

✔ Step 5 (Optional but Valuable): Deep Scan

- Install and run OpenVAS/Greenbone CE OR Nessus Community
- Export HTML/XML scan results

Evidence Collection (Required)

Evidence	Why it matters
Nmap scan files	Shows open attack surface
Nikto report	Server-side issues
Dirsearch output	Hidden entry points
Screenshots	Proof for report
(Optional) OpenVAS/Nessus reports	Deep enterprise-style assessment

Final Report (Professional Format)

Your final deliverable will be a **Vulnerability Assessment Report** consisting of:

Section	Description
Executive Summary	High-level view for non-technical readers
Methodology	Tools used, rules of engagement
Technical Findings	Each vulnerability with screenshots & evidence
Impact Analysis	Why this matters to security posture
Risk Rating	Critical / High / Medium / Low
Remediation	How to fix the issue
Conclusion	Summary & next steps

Free Resources (High Quality & Beginner Friendly)

Topic	Resource
Learn Nmap (Full Course)	https://www.stationx.net/nmap-cheat-sheet/
Nmap video training	https://youtu.be/3lUed36YVjI
Nikto practical tutorial	https://youtu.be/2bz0Uj7Xf40
Dirsearch GitHub	https://github.com/maurosoria/dirsearch
Vulnerability Assessment explained	https://owasp.org/www-project-vulnerability-assessment/
OpenVAS installation help	https://greenbone.github.io/docs/latest/

Deliverables (What you must submit)

- ✓ Vulnerability Assessment Report (PDF)
- ✓ Evidence folder (nmap, nikto, dirsearch outputs)
- ✓ Screenshots demonstrating findings
- ✓ Optional OpenVAS/Nessus report